Vulnerability Assessment Report

1st March 2026

System Description

The assessed system is a Windows Server 2019 Standard Evaluation virtual machine configured as a Domain Controller for the lab.local domain. The server runs on an AMD Ryzen 7 5700U processor with 3 GB of RAM allocated within a VirtualBox virtualised environment. The system hosts Active Directory Domain Services (AD DS) and DNS Server roles, managing authentication and name resolution for the domain. Network connectivity is provided through two virtual adapters — a NAT adapter for external access and an Internal Network adapter for isolated lab communication. The domain currently contains three standard user accounts in addition to the built-in Administrator account.

Scope

The scope of this vulnerability assessment covers the access control configuration and identity management setup of the lab.local Active Directory domain. The assessment was conducted on a single Domain Controller (DC-2019) running Windows Server 2019. The evaluation period covers the initial deployment phase of the domain environment. The assessment follows NIST SP 800-30 Rev. 1 guidelines for risk analysis.

Purpose

The purpose of this vulnerability assessment is to evaluate the security posture of the lab.local Active Directory domain infrastructure. The Domain Controller serves as the central authentication and authorisation system for all domain users and resources. Compromise of this system would result in full loss of access control across the entire domain environment, potentially exposing all user accounts, credentials, and domain resources to an attacker. The assessment aims to identify weaknesses in the current configuration and provide actionable recommendations to reduce the risk of unauthorised access, privilege escalation, and credential theft.

Risk Assessment

Threat Source	Threat Event	Likelihood	Severity	Risk
External attacker	Brute force Domain Administrator account	3	3	9
Malicious insider	Privilege escalation via shared weak passwords	2	3	6
External attacker	Credential theft due to weak cryptography settings	2	3	6
Employee	Unauthorised access due to missing account lockout policy	2	2	4
External attacker	Lateral movement due to missing network segmentation	1	3	3

Approach

This vulnerability assessment was conducted using a manual configuration review approach, guided by the NIST SP 800-30 Rev. 1 risk assessment framework. The assessment focused on the Active Directory domain configuration of DC-2019, examining user account settings, password policies, authentication mechanisms, and network adapter configuration.

Likelihood scores were determined based on the exposure level of each identified weakness — configurations that are directly exploitable without authentication received the highest likelihood ratings. Severity scores reflect the potential impact on domain integrity and confidentiality, with risks affecting the Domain Administrator account rated at maximum severity due to the full-domain compromise potential.

The assessment was limited to manual inspection of the domain controller configuration and did not include automated vulnerability scanning or penetration testing. No production systems or real user data were involved — the environment is an isolated virtualised lab built for educational and portfolio purposes.

Remediation Strategy

The following remediation measures are recommended to address the identified risks in order of priority:

1. Enforce a strong password policy for all domain accounts

A Group Policy Object (GPO) should be implemented to enforce minimum password length of 12 characters, complexity requirements, and a maximum password age of 90 days. All user accounts currently sharing identical passwords must be updated immediately.

2. Configure account lockout policy

A domain-wide account lockout policy should be configured to lock accounts after 5 failed login attempts, with a 30-minute lockout duration. This directly mitigates brute force attacks against the Domain Administrator and standard user accounts.

3. Disable legacy cryptography settings

The default Windows Server 2019 cryptography setting that allows algorithms compatible with Windows NT 4.0 should be disabled via Group Policy to prevent weaker encryption from being used during security channel sessions.

4. Implement Role-Based Access Control (RBAC)

User accounts should be assigned to appropriate security groups based on the principle of least privilege. Standard users such as John Smith and Mike Davis should not have administrative privileges. Sarah Johnson's IT admin account should be granted only the permissions required for her role.

5. Assign static IP addresses to network adapters

Both network adapters on DC-2019 should be configured with static IPv4 addresses to ensure reliable DNS resolution and stable domain authentication services.